

ชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก

HONEYPOT PROGRAM SUITE

นาย ชีรชัย เรืองสูง

นาย ธนวัชร ลิ้มปีพัฒนชัย

นาย อาทิตยพงษ์ สุชินโรจน์

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต

สาขาวิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์

สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

พ.ศ.2548

ชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก
HONEYPOT PROGRAM SUITE

โดย
นาย ชีรชัย เรืองสูง
นาย ธนวัชร ลิ้มปีพัฒนชัย
นาย อาทิตยพงษ์ สุชินโรจน์

อาจารย์ที่ปรึกษา
อ. อัครเดช วัชรระภูพงษ์
อ. ธนัญชัย ศรีภาค
ผศ. ธนา หงษ์สุวรรณ

ปริญญานิพนธ์นี้เป็นส่วนหนึ่งของการศึกษาตามหลักสูตรปริญญาวิศวกรรมศาสตรบัณฑิต
สาขาวิชาวิศวกรรมคอมพิวเตอร์
คณะวิศวกรรมศาสตร์
สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง
พ.ศ.2548

ปริญญานิพนธ์ปีการศึกษา 2548

ภาควิชาวิศวกรรมคอมพิวเตอร์

คณะวิศวกรรมศาสตร์ สถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบัง

เรื่อง ชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก

Honeypot Program Suite

ผู้จัดทำ

1. นายธนวัชร ลิ้มพัฒนาชัย รหัสนักศึกษา 45010320
2. นายธีรชัย เรืองสูง รหัสนักศึกษา 45010350
3. นายอาทิตย์พงษ์ สุชินโรจน์ รหัสนักศึกษา 45010965

_____ อาจารย์ที่ปรึกษา
(อาจารย์ อัครเดช วัชรานุพงษ์)

_____ อาจารย์ที่ปรึกษา
(อาจารย์ ธนัญชัย ตริภาค)

_____ อาจารย์ที่ปรึกษา
(ผู้ช่วยศาสตราจารย์ ธนา หงษ์สุวรรณ)

ชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก

นาย ธนวัชร ลิ้มพัฒนาชัย	45010320
นาย ชีรชัย เรืองสูง	45010350
นาย อาทิตยพงษ์ สุชินโรจน์	45010965
อ. อัครเดช วัชรภพพงษ์	อาจารย์ที่ปรึกษา
อ. ธนัญชัย ตรีภาค	อาจารย์ที่ปรึกษา
ผศ. ธนา หงษ์สุวรรณ	อาจารย์ที่ปรึกษา
ปีการศึกษา 2548	

บทคัดย่อ

การบุกรุกเข้ามาในระบบในปัจจุบันมีความสลับซับซ้อน และกลวิธีใหม่ๆ เกิดขึ้นอยู่ตลอดเวลา และถึงแม้ว่าเครือข่ายในองค์กรจะมีการป้องกันโดยใช้เครื่องมือป้องกันต่างๆ เช่น ไฟร์วอลล์, ระบบตรวจจับผู้บุกรุกและการปรับปรุงระบบให้ทันสมัยอยู่เสมอแล้ว ก็ยังพบว่ายังมีการเจาะระบบเข้ามาได้ โดยอาศัยช่องโหว่ต่างๆ รวมถึงการตั้งค่าการใช้งานที่ไม่เหมาะสม และจากความสามารถอันจำกัดของเครื่องมือป้องกันระบบที่ส่วนใหญ่จะเป็นแบบRules-base ซึ่งจะอาศัยกฎและฐานข้อมูลที่มี เป็นตัวตัดสินใจว่าเข้าข่ายบุกรุกหรือจำเป็นต้องกำจัดการแจ้งเตือนนั้นหรือไม่ ซึ่งการบุกรุกแบบใหม่ๆ ที่ไม่มีในกฎหรือในฐานข้อมูลก็จะสามารถกระทำได้โดยไม่ถูกตรวจพบ ดังนั้นนอกจากการปรับปรุงระบบและใช้เครื่องมือช่วยป้องกันระบบที่เหมาะสมแล้ว ยังมีประโยชน์อย่างยิ่งในการเข้าใจอย่างแท้จริงในแนวคิดและวิธีการของผู้บุกรุก ว่ามีการกระทำอย่างไรบ้าง ซึ่งจะสามารถนำมาประยุกต์เพื่อป้องกันระบบของเราได้ดียิ่งขึ้น ซึ่งตัวอันนี้ที่ชื่อชุดโปรแกรม จะทำหน้าที่คัดแยกผู้ใช้งานที่มีพฤติกรรมที่น่าสงสัย ออกจากระบบจริง เข้าสู่ระบบเสมือนเพื่อเฝ้าดูและศึกษาพฤติกรรม เพื่อทราบวิธีการที่ผู้บุกรุกกระทำ โดยที่การกระทำใดๆ ของผู้บุกรุกก็จะไม่ส่งผลกระทบหรือทำอันตรายต่อระบบจริง

HONEYPOT PROGRAM SUITE

Mr. Tanawach	Limpadtanachai	45010320
Mr. Theerachai	Ruangsoong	45010350
Mr. Arthittayapong	Suchinroj	45010965
Mr. Akkradach	Watcharapupong	Advisor
Mr. Tanunchai	Tripak	Co-Advisor
Asst.Prof. Thana	Hongsuwan	Co-Advisor
Academic Year 2005		

ABSTRACT

In the present intruder have many new techniques and tools to intrude in our organization. Even if we use many tools to prevent our organization but it's work with it's knowledge base or rules that they set. All most security tools cannot protect and prevent all problems of security of organization. There is no tool which can learn behaviors of hackers, so Honeypot was introduced to solve these problems. Honeypot, a new generation tool , is a trap set to detect or deflect attempts at unauthorized use of information systems and about send the intruders to the virtual system at this we can observe their behavior and capture it without damage that may occurred with real system. So we can learn about their techniques and methods. That will help us to approve our organization.

กิตติกรรมประกาศ

เอกสารฉบับนี้และตัวชิ้นงานชุดโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุกสำเร็จลุล่วงได้ด้วยดี ก็เนื่องมาจากการให้โอกาส การดูแล ให้คำแนะนำต่างๆ การสนับสนุน การให้คำสั่งสอนและให้คำปรึกษาเป็นอย่างดีเสมอมา จากท่านอาจารย์ อัครเดช วัชรภูพงษ์ ท่านอาจารย์ ธนัญชัย ศรีภาค และท่าน ผศ. ธนา หงษ์สุวรรณ ซึ่งต้องขอขอบพระคุณอาจารย์ทั้ง 3 ท่านเป็นอย่างสูง ขอขอบคุณภาควิชาวิศวกรรมคอมพิวเตอร์ และสถาบันเทคโนโลยีพระจอมเกล้าเจ้าคุณทหารลาดกระบังที่ได้จัดเตรียมสิ่งอำนวยความสะดวก เพื่อให้งานวิจัยดำเนินไปได้อย่างสะดวกและรวดเร็ว ขอขอบคุณห้องวิจัยไอแซค (ISAG) ที่เป็นแหล่งประสิทธิ์ประสาทวิชาให้ความรู้ความเข้าใจ เป็นสถานที่ ที่มีความอบอุ่น ท่านอาจารย์ พี่ๆ ที่เป็นผู้ให้แนวทางแก้ไขและที่ปรึกษาของชิ้นงานจนลุล่วงด้วยดี

สุดท้ายนี้ข้าพเจ้าขอกราบขอบพระคุณ บิดา มารดา และครอบครัวของข้าพเจ้าที่เป็นกำลังใจ และให้การสนับสนุนในทุกเรื่องๆ ทำให้ข้าพเจ้าสามารถทำวิทยานิพนธ์ฉบับนี้สำเร็จลุล่วงด้วยดี

คุณค่าและประโยชน์อันพึงมาจากวิทยานิพนธ์ฉบับนี้ ข้าพเจ้าขอบแต่ผู้มีพระคุณทุกท่าน

นาย ชีรชัย เรืองสูง

นาย ธนวัชร ลิ้มปัทมชัย

นาย อาทิตยพงษ์ สุชินโรจน์

สารบัญ

หน้า

บทคัดย่อภาษาไทย.....	I
บทคัดย่อภาษาอังกฤษ.....	II
กิตติกรรมประกาศ.....	III
สารบัญ.....	IV
สารบัญตาราง.....	VIII
สารบัญรูป.....	IX
บทที่ 1 บทนำ.....	1
1.1 ความสำคัญและที่มาของโครงการ.....	1
1.2 วัตถุประสงค์ของโครงการ.....	1
1.3 ขอบเขตของโครงการ.....	2
1.4 วิธีการดำเนินการ.....	2
1.5 ประโยชน์ที่คาดว่าจะได้รับ.....	2
1.6 ส่วนประกอบของปริญญานิพนธ์.....	3
บทที่ 2 ทฤษฎีพื้นฐานที่ใช้ในการพัฒนาระบบอัตโนมัติ.....	4
2.1 แนวคิดเริ่มต้นของอัตโนมัติ.....	4
2.2 วิวัฒนาการของอัตโนมัติ.....	4
2.4 ความรู้พื้นฐานเกี่ยวกับการบุกรุก.....	6
2.5 ความรู้พื้นฐานเกี่ยวกับไฟลว์อล.....	8
2.6 ความรู้พื้นฐานเกี่ยวกับระบบตรวจจับผู้บุกรุก.....	12
บทที่ 3 ระบบอัตโนมัติ.....	14
3.1 องค์ประกอบของระบบอัตโนมัติ.....	14
3.2 หน้าที่การทำงานในแต่ละส่วนและเครื่องมือที่ใช้.....	16
3.2.1 จำแนกผู้บุกรุกออกจากผู้ใช้งานทั่วไปและส่งเข้าใช้งานเครื่องกับดัก.....	16
3.2.2 ส่วนเฝ้าบันทึกพฤติกรรม และควบคุมขอบเขตของผู้บุกรุก.....	19
3.2.3 ส่วนจัดเก็บข้อมูลกลาง.....	23
3.2.4 ส่วนการจัดการและตรวจสอบสภาพความเสียหายของเครื่องกับดัก.....	27

สารบัญ (ต่อ)

หน้า

3.2.5 ส่วนการควบคุมและแสดงผลการบันทึกข้อมูลต่างๆของระบบ	27
3.3 การทำงานร่วมกันของระบบ.....	28
3.4 สรุปการทำงานของระบบโดยรวม.....	30
3.5 ข้อจำกัดของฮาร์ดแวร์ที่ออกแบบเดิม.....	31
3.6 รูปแบบระบบฮาร์ดแวร์ที่เรากำลังพัฒนาขึ้นใหม่.....	31
3.7 ข้อควรระวังในการใช้งานระบบฮาร์ดแวร์ที่ออกแบบ.....	32
บทที่ 4 เครื่องมือที่นำมาประยุกต์ใช้งาน.....	33
4.1 Sebek.....	33
4.2 Samhain.....	36
4.3 Snort_inline.....	39
4.4 IPsec.....	41
4.5 S2I.....	45
4.6 Iptables.....	46
บทที่ 5 เครื่องมือที่พัฒนาขึ้นใหม่.....	53
6.1 Tartarus Management.....	53
6.2 Cage Prototype.....	58
บทที่ 6 การทดลองและผลการทดลอง.....	59
6.1 โครงสร้างระบบ.....	59
6.2 ขั้นตอนการทดสอบชุดโปรแกรม.....	60
6.3 ผลการทดลอง.....	61
บทที่ 7 บทวิจารณ์และสรุป.....	72
7.1 บทสรุป.....	72
7.2 วิจารณ์สิ่งที่ได้จากโครงงาน.....	72
7.3 ปัญหาอุปสรรคและแนวทางแก้ไข.....	73

สารบัญ (ต่อ)

	หน้า
7.4 แนวทางการพัฒนาต่อ.....	73
บรรณานุกรม.....	75

สารบัญตาราง

ตารางที่	หน้า
4.1 ตารางแสดงความสามารถของ AH, ESP และ AH+ESP.....	41
6.1 ตารางกำหนดหมายเลขไอพีประจำเครื่องแต่ละเครื่อง.....	61

สารบัญรูป

รูปที่	หน้า
2.1 แสดงการทำงานของระบบตรวจจับผู้บุกรุก.....	12
3.1 แสดงโครงสร้างของโปรแกรมจำแนกและบันทึกพฤติกรรมผู้บุกรุก.....	14
3.2 แสดงรูปแบบการวางทับข้อมูลในแฟ้มเกิดของระบบตรวจจับผู้บุกรุก.....	21
3.3 แสดงการเชื่อมต่อระหว่างส่วนต่าง ๆ เพื่อทำการจำแนกผู้ใช้งานปกติกับผู้บุกรุกแบบเก่า.....	28
3.4 แสดงการเชื่อมต่อระหว่างส่วนต่าง ๆ เพื่อทำการจำแนกผู้ใช้งานปกติกับผู้บุกรุกแบบใหม่.....	29
3.5 แสดงการทำงานของส่วนจำแนกและกำหนดทิศทางการเชื่อมต่อ.....	29
4.1 แสดงการทำงานของ Sebek.....	34
4.2 แสดงการcapture ข้อมูลที่ทำภายใน kernel.....	34
4.3 แสดงการby-pass ไม่ผ่าน TCP stack.....	35
4.4 แสดงองค์ประกอบการทำงาน.....	41
4.5 แสดงรูปแบบแฟ้มเกิดของ IPsec.....	42
4.6 แสดง Authentication Header.....	43
4.7 แสดง Encapsulated Security Payload.....	44
4.8 แสดงไดอะแกรมแสดงการทำงานของ S2I.....	45
5.1 แสดงโปรแกรม TM (Tartarus Management).....	53
5.2 แสดงรูปในส่วนที่ใช้ในการกำหนดกฎให้กับระบบตรวจจับผู้บุกรุก.....	54
5.3 แสดงส่วนจัดการเครื่องกับดัก.....	55
5.4 แสดงข้อมูลของเครื่องกับดัก.....	56
5.5 แสดง log ที่เก็บอยู่ในฐานข้อมูลในเครื่อง Logserver.....	57
6.1 แสดงโครงสร้างโครงระบบที่ทำการทดลอง.....	59
6.2 แสดงสถานะกฎของไอพีเทเบิล.....	62
6.3 แสดงรายละเอียดของเครื่องกับดักต่างๆ.....	62
6.4 แสดงรายละเอียดของการเชื่อมต่อ.....	63
6.5 แสดงการเชื่อมต่อของเครื่องกับดัก.....	63
6.6 แสดงถึงการพยายามบุกรุกเครื่อง FTP.....	64
6.7 แสดงตาราง NAT ของเครื่อง honeywall.....	64
6.8 ผู้บุกรุกได้เข้ามายังเครื่อง FTP ได้สำเร็จ.....	65
6.9 แสดงสถานะของเครื่องกับดักในขณะที่ cage1 ได้ start แล้ว.....	65

สารบัญ (ต่อ)

หน้า

6.10	แสดงการเชื่อมต่อของเครื่องกับคัตหลังจากผู้บุกรุกเข้ามาแล้ว.....	66
6.11	แสดงการใช้คำสั่ง route เพื่อตรวจสอบตัวตน.....	66
6.12	แสดงการใช้คำสั่ง ping เพื่อตรวจสอบตัวตน.....	67
6.13	แสดงการใช้คำสั่ง ifconfig เพื่อตรวจสอบตัวตน.....	67
6.14	แสดงการใช้คำสั่ง vi ไฟล์ /etc/passwd.....	68
6.15	แสดงข้อมูลที่ได้จากการเก็บพฤติกรรมมาจากเครื่องกับคัต.....	68
6.16	แสดงข้อมูลในไฟล์ /etc/shadow ก่อนถูกเปลี่ยนแปลง.....	69
6.17	แสดงการที่ผู้บุกรุกพยายามทำการแก้ไขไฟล์ /etc/shadow.....	69
6.18	แสดงข้อมูลในไฟล์ /etc/shadow หลังเปลี่ยนแปลงแล้ว.....	70
6.19	แสดงตาราง NAT ของเครื่อง Honeywall.....	70
6.20	แสดงข้อมูลของเครื่องกับคัตในเครื่อง Logserver.....	71
6.21	แสดงข้อมูลของเครื่องต่างๆ ในระบบ.....	71